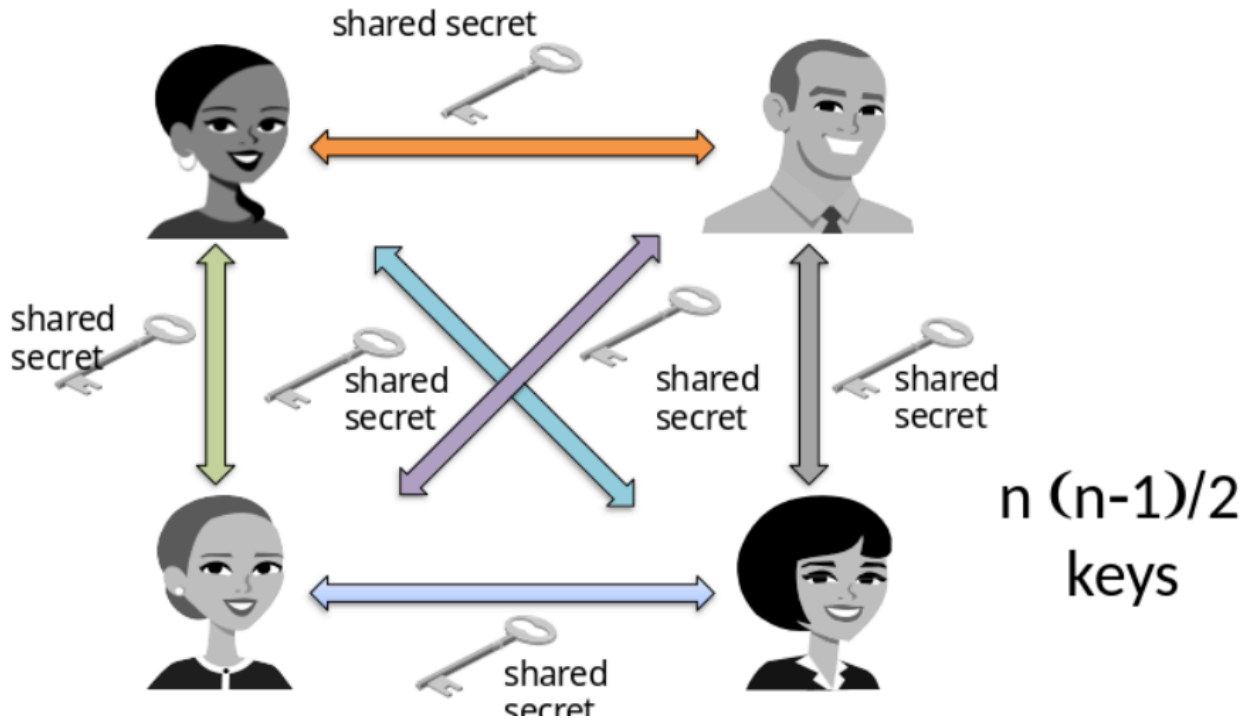
Security-2

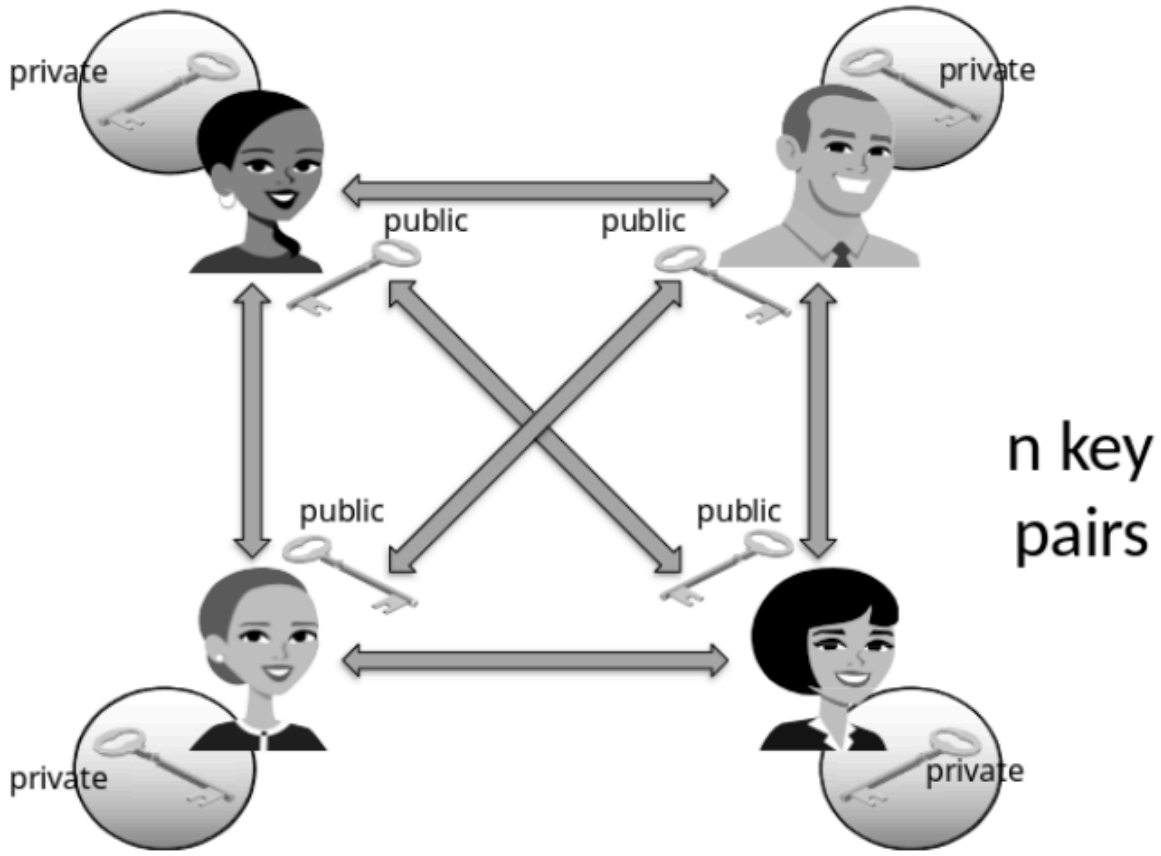
Simetrik Anahtar Dağıtımı

- Her 2 kişi arasında 1 anahtar paylaşılır ve bu kişiler bu anahtar sayesinde birbirleriyle iletişim kurarlar
- Simetrik anahtar paylaşımı terimi her iki taraf için de anahtarın aynı olmasından gelir.
- n kişilik bir gruptaki simetrik anahtar sayısı [n.(n-1)]/2 fprmülüyle bulunur.



Public Key

- A kişisi B kişisine mesaj göndermek istediğinde;
  1. B kişisinin public key'ini kullanarak mesajı şifreler ve gönderir.
  2. B kişisi kendi private key'ini kullanarak şifreyi çözer ve orijinal mesajı okur.
- n kişilik bir grup için n adet public key ve n adet private key gerekir.



Dijital İmza

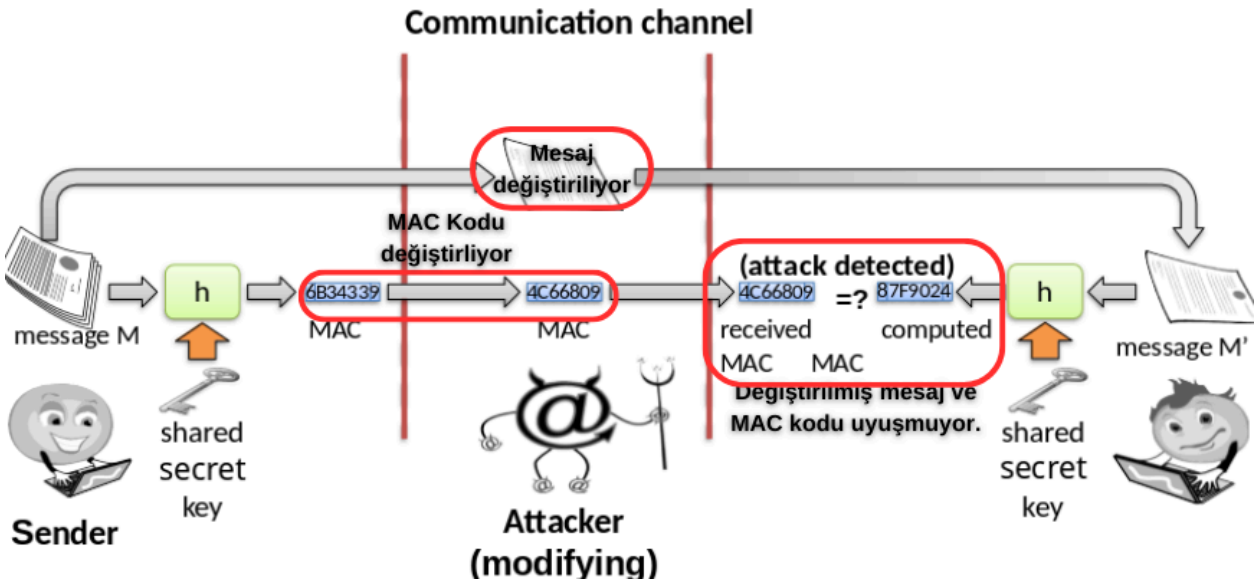
- Genellikle public key yöntemi kullanılır ancak bu işlem tersten gerçekleşir.

1. A kişisi private key'ini kullanarak mesajını imzalar.
2. B kişisi bu mesajın A kişisine ait olduğundan emin olmak için A kişisinin public key'ini kullanarak şifreyi çözer.
3. Çözdüğü mesaj ile A kişisinin imzasını karşılaştırır ve aynıysa bu mesajın A kişisine ait olduğunu anlar.

Mesaj Doğrulama Kodları (MACs) & Hash

- Gönderilen ve alınan mesajın doğruluğundan emin olmak için kullanılır.
- Kişiler arasında private key paylaşılır.

1. Gönderici göndereceği mesajla gizli şifreyi kullanarak MAC kodu oluşturur. (Hash'lar)
2. Gönderici MAC koduyla mesajı alıcıya gönderir.
3. Alıcı paylaşılmış private key ile metni hash'lar ve çıkan MAC kodu ile gönderileni karşılaştırır.
4. Eğer MAC adresleri uyuşmazsa mesaj, mac kodu veya her ikisi de değiştirilmiş demektir.



Dijital Sertifikalar

- Sertifika yetkisi, bir kimlik ile o kimliğe ait public key arasındaki bağlayıcı dijital imzadır.

Şifreler

Şifre Gücü

- n farklı karakterdan oluşan bir havuzdan k karakterlik bir şifre oluşturulmak isteniyorsa n^k tane olasılık vardır.
- Güçlü bir şifre en az 3 türden karaktar içermelidir.

1. Küçük harfler
2. Büyük Harfler
3. Numaralar
4. Semboller
5. Unicode karakterler (£,omega,alpha...)

Parolaları Saklama

- Rastgele tuzlama (random salt) kullanılır.
- Salt'larla şifre hash'lanır ve hashcode depo edilir.
- Ele geçirilse bile çözülemez.

Malware (Kötü Amaçlı Yazılım)

Virüs

- Kendini gerçek bir virüs gibi çoğaltır
- Diğer programları değiştirir ve kendini bu programlara ekler.

Worm (Solucan)

- Ağ üzerinde kendini diğer bilgisayarlara kopyalayabilir.
- Creeper ilk bilgisayar solucanıydı, Reaper ise Creeper'ı ortadan kaldırmak için tasarlanmış ilk antivirüs yazılımıydı.

Trojan

- Kendini makineye sokmak için kullanıcıya zararsız bir program gibi gözükür.

Dropper'ler

- Enfekte ettikleri sisteme kötü amaçlı yazılım yüklemeye çalışan trojan alt türüdür.
- Algılanmamak için gizlilikle çalışır.

- Sistem üzerinde hafif yük oluşturarak fark edilmeyi zorlaştırır.

Spyware

- Kullanıcı davranışlarını izler, alakasız reklamlar gösterir.
- Virüsler gibi kendini yayılmaz, güvenlik açıklarından yararlanılarak yüklenir
    - Ayrıca başka bir programın içinde paketlenmiş halde de sızabilir.

Ransomware (Fidye Yazılımı)

- Ücret ödenene kadar dosyalara erişimi engeller.

Rootkits

- Zararlı yazılımların işletim sistemi tarafından fark edilmemesi için sistemde değişiklikler yapar.
- Görünmesini engelleyebilir ya da dosyaların okunmasını önleyebilir.

Bazı Terimler

Bug

- Kaynak kodunda yaşanan bi hatadır
- Kolayca düzeltilebilir ve maliyetsizdir.

Flaw

- Tasarımda veya anlayışta yaşanan bir sıkıntı sonucu oluşan bir hatadır.
- Düzeltmesi zor ve maliyetlidir.

Güvenlik Açığı

- Bir yazılım hatası, kusurdur.
- Güvenlik açıkları bilgisayarlarda, ağlarda, işletim sistemlerinde veya uygulamalarda olabilir.

Networks

Wireshark

- Bir protokol analizörüdür.
- Ağ trafiğini izleyen ve ne tarafından, ne zaman, kime, ne gönderildiği analiz etmemizi sağlayan bir araçtır.

Ağ Saldırıları: Ağ Dinleme

- Ağ trafiğindeki çoğu dosya şifrelenmemiş düz metinlerdir.

Ağ Dinleme Araçları

1. Ettercap & Bettercap
    a. Ağ analizi için tasarlanmamışlardır ancak şu özelliklere sahiptirler:
        i. Şifre ele geçirme.
        ii. Ortadaki adam (dinleme) saldırısı yürütme.
        iii. Oturumları ele geçirme.
2. Kali Linux Araçları
    a. dsniff: Parola çalar.
    b. webspy: Girilen URL'leri yakalar.
    c. mailsnarf: POP veya SMTP tabanlı postaları yakalar.

Ağ Dinlemesi Nasıl Önlenebilir

- Şifreleme ve şifrelenmiş ağ protokolleri kullanılabilir.
- Örneğin HTTPS ve VPN (Visual Private Network)

Ağ Saldırıları: Ağ Taraması

- Ağ taramasıyla hangi cihazların, hizmetlerin çalıştığı; hangi portların açık olduğu bulunabilir.

- Bunun için Shodan ve Zoomeye gibi yazılımlar kullanılabilir. (Fping, Nmap, NETcat,)

Ağ Saldırıları: Dağıtılmış Hizmet Reddi (DDoS)

- Aynı anda birden çok isteği sunucuya göndererek çalışamaz hale getirme saldırısıdır.

DDoS Tipleri

1. SYN Flood
    a. Sunucuya çok fazla istek göndererek hizmeti çalışamaz hale getirir.
2. Ping of Death
    a. IP sözleşmesini ihlal eder.
    b. Beklenmeyen hatalara neden olmak için büyük paketler gönderir.

URL

- Örnek: https://www.google.com/search?**q=grand+theft+auto**&**lr=lang_zh-TW**
    - q = “Sorgulama” için sorgu dizisinde google’nin anahtarı
    - lr = “Language (dil)” için sorgu dizisinde google’nin anahtarı

HTTP İsteği

- Header (Başlık)
    - GET: Sunucudan veri indir. (Adres çubuğuna URL yazdığınızda her zaman kullanılır.)
    - POST: Bir formdan sunucuya gönderilir.
    - PUT: Yükleme
    - DELETE
- Body
    - Sunucuya gönderilecek veriler buraya yazılır. (Sorgu dizesi anahtar değer çiftleri dahil.)

HTTP Cevabı

- Header
  - 200: OK
  - 300: Kalıcı olarak taşındı
  - 302: Bulundu (İstek başka bir URL'ye yönlendirildi.)
  - 401: Yetkisiz
  - 403: Yasak
  - 404: Bulunamadı
  - 500: Dahili sunucu hatası
- Body
  - İçerik verilero bulunur. (HTML, CSS, JSON...)

Web Güvenliği

The Open Worldwide Application Security Project (OWASP)

- Yazılım güvenliğini iyileştirmek için çalışan, kâr amacı gütmeyen bir vakıftır.

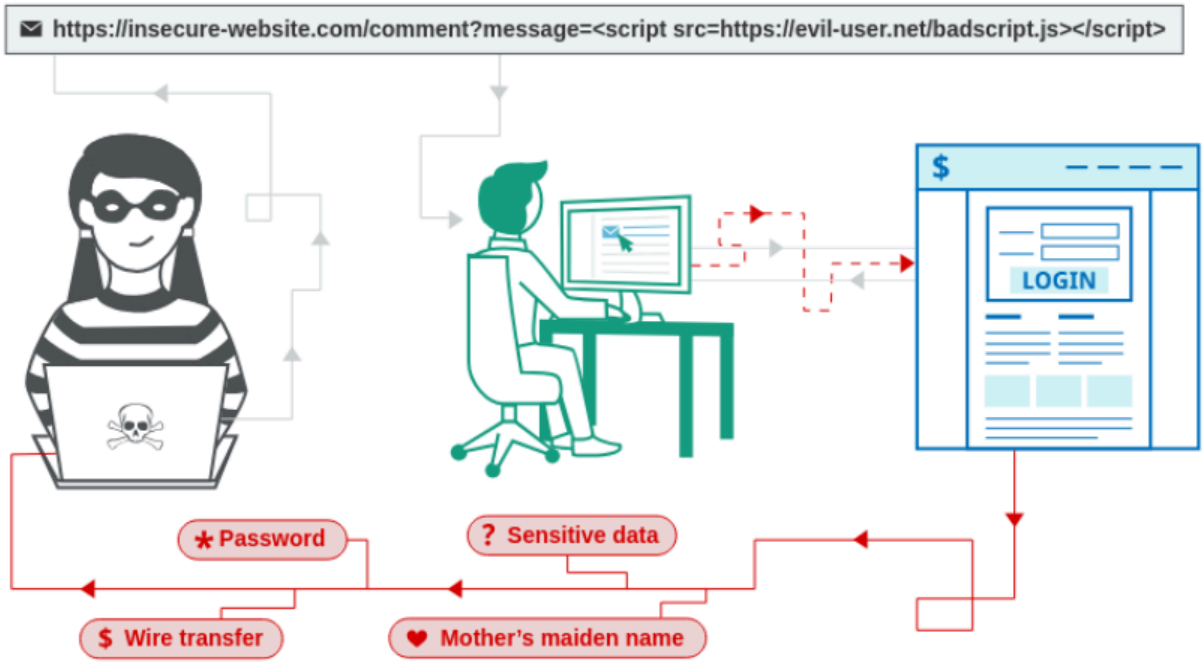
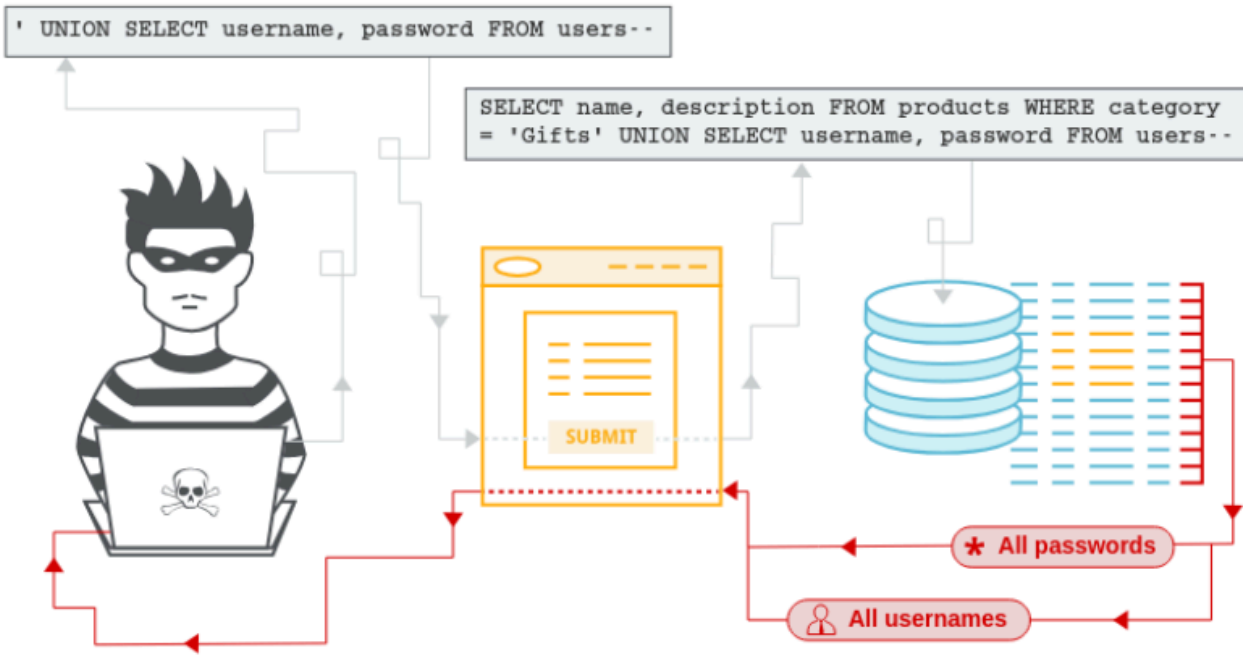
Metaspoitable 2

- Kasıtlı olarak savunmasız bırakılmış bir Linux makinesidir.

Web Güvenliğini Test Etmek için Bazı Araçlar

- Burp Suite
- OWASP Zed Attack Proxy (ZAP)
- Tamper Data for Firefox
- mitmproxy

Cross-Site Scripting



SQL Injection